Ders 7 Lab Çalışma Özeti

Ders 7 Lab Çalışma Özeti

Genel Konular

- SQL injection laboratuvar ortamı
  - PHP ve MySQL tabanlı bilinçli zafiyetli web uygulaması üzerinden SQL injection örnekleri uygulanır.
  - Apache, MySQL, PHP bağlayıcıları ve uygulama kaynak kodu kullanılarak test ortamı hazırlanır.
- Low seviye SQL injection
  - Kullanıcı girdisinin doğrudan SQL sorgusuna eklenmesiyle syntax hatası, yorum satırı ve `UNION` gibi SQL özellikleri üzerinden sorgu manipülasyonu yapılır.
  - Veritabanı sürümü, aktif veritabanı adı, tablo ve kolon bilgileri gibi metadata elde edilebilir.
- Hata mesajlarının bilgi sızdırması
  - SQL hatalarının doğrudan kullanıcıya gösterilmesi saldırgana kullanılan veritabanı ve sorgu yapısı hakkında ipucu verir.

Hocanın Özellikle Vurguladığı Kısımlar

- SQL injection komutun veriyle karışmasıdır
  - Kullanıcı girdisi veri olarak sınırlandırılmazsa SQL komutu haline gelebilir.
- Hata mesajları saldırıyı kolaylaştırır
  - Veritabanı hatası web katmanında aynen gösterilmemelidir.
- `UNION` saldırganın ek sorgu sonucu almasını sağlar
  - Sorgu kolon sayısı ve tipleri uyumlu hale getirilirse başka tablolardan veri çekilebilir.

Kısa Tekrar Notları

- SQL injection kullanıcı girdisiyle sorgu mantığını değiştirir.
- Tek tırnak syntax hatası üretip zafiyeti gösterebilir.
- SQL comment kalan sorguyu devre dışı bırakabilir.
- `UNION SELECT` farklı sorgu sonuçlarını birleştirebilir.
- Metadata tabloları veritabanı yapısını açığa çıkarabilir.

Detaylı Açıklamalar

- Laboratuvar uygulamasında zafiyetli web formuna girilen değerlerin arka planda SQL sorgusuna nasıl eklendiği incelenir. Tek tırnak gibi karakterler sorgu dizgisini bozarak hata üretir; bu hata uygulamanın girdiyi güvenli biçimde ayırmadığını gösterir.
- Saldırgan yorum işaretleriyle sorgunun kalan kısmını devre dışı bırakabilir veya `UNION` ile kendi seçtiği sorgu sonuçlarını mevcut sorguya ekletebilir. Bu yöntemle veritabanı sürümü, aktif kullanıcı, tablo adları, kolon adları ve hassas kayıtlar adım adım elde edilebilir.
- Güvenli tasarım açısından parametreli sorgular, prepared statement kullanımı, hata mesajlarını gizleme, minimum veritabanı yetkisi ve girdi doğrulama birlikte uygulanmalıdır.

- **Not:** İsterseniz bu dersin altyazı (.srt) dosyasını Gemini Notebook gibi bir yapay zeka aracına yükleyerek ders hakkında daha detaylı soru-cevaplar yapabilir ve dersi verimli çalışabilirsiniz.